

# RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

## A Juliet score we can stand behind

### Where this fits

Juliet is a large public Java suite. The simple checker scores 0.316 there. An earlier model score on Juliet was withdrawn because the question showed the answer.

This note is the replacement. The model sees cleaned code. Comments that say "flaw" are blanked, and obvious names such as bad and good are renamed. The true label is used only when we score the answer, not when we ask the question.

### What we did

A Juliet pair is one unsafe file and the matching safe file. The model is right only if it calls the bad file unsafe and the good file safe. If it says "not sure" on either file, the pair is wrong.

We sampled pairs from single-file examples, three pairs from each weakness family that Juliet actually contains, with a fixed random seed so the sample can be repeated. Some Juliet examples hide the risky line in a second file. Those were left out, because the model would never see that line.

Seventeen pairs were complete. The model got 9 right. That is 0.529. Seventeen is a small sample, so we reshuffled those 17 results many times. The score usually lands between 0.294 and 0.765. The range is wide. A single 0.529 should not be treated as a precise ranking against other papers.

One more pair was cut off. The free daily token limit stopped the run after 35 of 36 files. We leave that pair out of the 9-of-17 count. It is a stopped run, not a model mistake. The status of the model row is partial.

If we ignore the pair rule and score each file alone, F1 on the 35 scored files is 0.789. That number is easier to inflate, because a model can mark both files unsafe and still look good on the unsafe ones. The pair score is the one we stand behind.

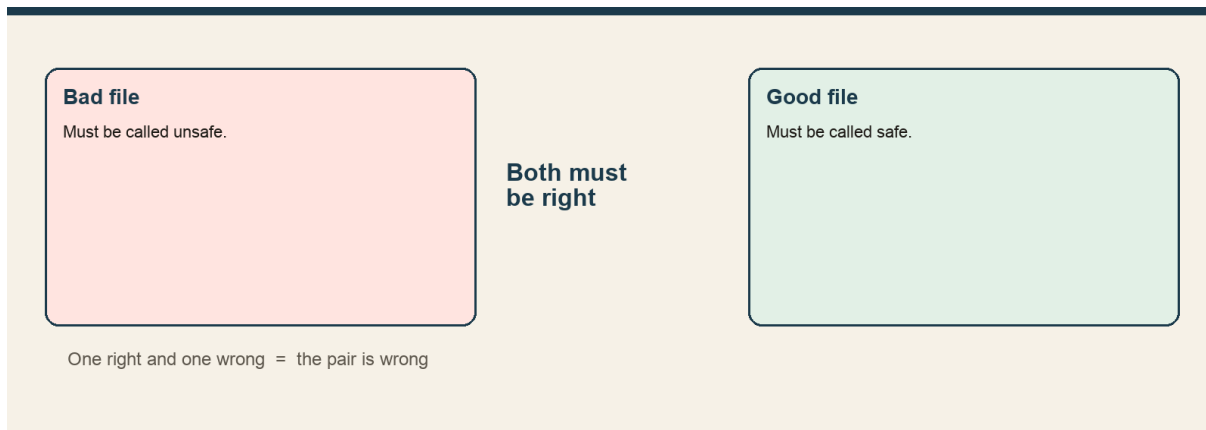
### A concrete example

Take one pair. The bad file builds a query in an unsafe way. The good file does the safe version of the same lesson. If the model says both are unsafe, it got the bad file right and the good file wrong. The pair counts as wrong.

If it says the bad file is unsafe and the good file is safe, the pair counts as right. That is one of the 9.

The range 0.294 to 0.765 means a different draw of 17 pairs could have looked much better or much worse. We show the range so 0.529 is not treated as exact.

### Picture



Both files in a pair have to be judged correctly. One right answer is not enough.

## The numbers

| Item                                   | Value          |
|----------------------------------------|----------------|
| Complete pairs correct                 | 9 of 17        |
| Pair accuracy                          | 0.529          |
| Likely range if the sample is repeated | 0.294 to 0.765 |
| Files scored before the token limit    | 35 of 36       |
| F1 if each file is scored alone        | 0.789          |

Use 9 of 17, with the range, when talking about Juliet. Do not replace it with the 0.789 file-level F1, and do not mix it with the 0.923 score on our own 24 files.

## Closing

This is the public model number we can defend today. It is modest, and the range is wide.

We still have not run these same pairs with CWE search turned off. Until that run exists, we cannot say whether the book helps on Juliet. A local screen for running these tests is the practical next step, together with that missing comparison.

## What we are not saying

We do not say that CWE search helps on Juliet. We do not say this is the best published detector.